M. Auditability, Compliance & Evidence

Standalone capability brief · Suggested module: **Audit + Compliance Platform**

Purpose

Create trustworthy records of security-sensitive and business-significant actions and make evidence collection repeatable for audits, access reviews, and regulatory obligations.

1. Scope and capability areas

Audit record integrity

Use append-oriented, access-controlled, and where needed tamper-evident records.

Administrative history

Record actor, action, target, timestamp, outcome, and relevant change summary.

Policy-decision history

Capture decision identifiers and reason codes while minimizing sensitive data.

Access reviews

Support periodic permission recertification, exceptions, and remediation tracking.

Evidence collection

Collect configuration, deployment, control-test, and operational evidence with provenance.

Retention and legal hold

Apply distinct retention and access rules to audit records and compliance artifacts.

Data-subject requests

Track privacy access, export, correction, and erasure workflows end to end.

Separation of duties

Require independent approvals for high-risk operations where policy demands it.

2. Shared contracts and standards

- Audit records are distinct from debug logs, security telemetry, and business analytics.
- Events use a stable schema and include actor, action, target, time, result, source, and correlation identifiers where appropriate.
- Audit writers cannot freely rewrite historical records; administrative access is tightly controlled.
- Compliance evidence records its collection time, source, scope, and integrity metadata.

3. Recommended implementation approach

- Define an event taxonomy and canonical schema for administrative and business audit events.
- Provide SDKs and middleware for high-value event capture.
- Restrict access and export paths, and monitor attempts to alter or suppress audit records.

- Automate evidence collection and access-review reminders.
- Test retention, legal hold, export, and recovery behavior.

4. Failure behavior and operational expectations

- Critical audit capture failures should alert and may block high-risk operations according to policy.
- Evidence gaps must be reported as gaps rather than silently treated as compliant.
- Retention changes require authorization and an auditable change record.

5. Suggested operational metrics

- Audit event coverage for critical actions
- Evidence collection freshness
- Access-review completion rate
- Audit pipeline lag and loss
- Overdue remediation items

6. Readiness and acceptance checklist

- ■ Critical actions produce structured audit records.
- ■ Audit data has access, integrity, and retention controls.
- ■ Evidence can be traced to source systems and collection times.
- ■ Access reviews and remediation have owners and deadlines.

Ownership note: assign a named team, service owner, support route, versioning policy, and deprecation process before treating this capability as a platform contract.